

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)



Governance, Compliance, and Risk (GCR)

Course 3: GRC103 – Risk Assessment and Management Techniques

OWASP Top 10 Assessment of Legacy Web Applications

Student Name: Ester Hunja

Reg. No: 2025/GRC/10983

September 25, 2025

**ICDFA
NIGERIA**

1. Executive Summary

An urgent security assessment of the **owaspbwa** server, a legacy web application platform, revealed **multiple high-severity security failures** across the application and infrastructure layers. This system poses an unacceptable risk of data loss and compliance failure due to systemic deficiencies in development and patch management. The assessment confirmed flaws across five OWASP Top 10 categories, including Injection and widespread use of outdated components.

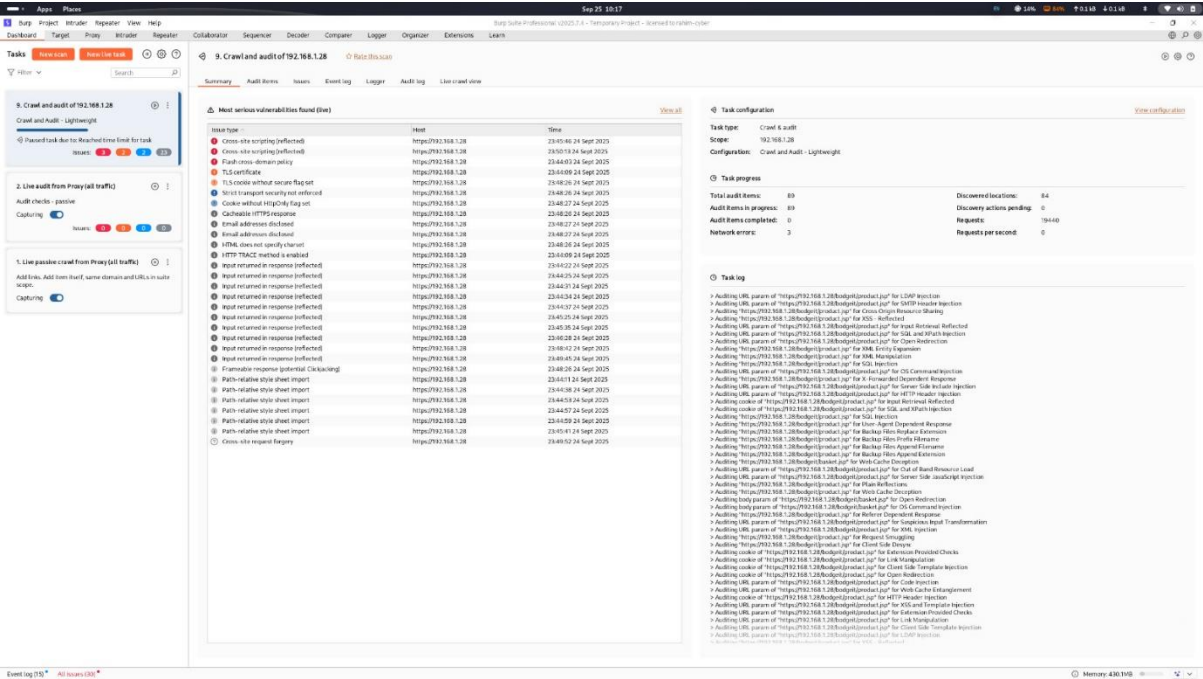
Action Recommended: The target system must be placed under immediate quarantine and a mandated remediation plan must begin immediately to address these critical flaws.

2. Key Findings and Risks

The assessment confirmed the following critical risks, which represent severe violations of application security policy and industry best practices.

2.1. A03: Injection (SQL Injection - Critical Risk)

This is the most critical finding, confirmed by automated scanning. The application fails to properly sanitize user input, allowing an attacker to inject malicious SQL commands directly into the database query. This vulnerability provides a pathway for an unauthorized party to bypass application logic, potentially steal or destroy the entire database, and cause a complete data breach.



2.2. A06: Vulnerable and Outdated Components (Critical Infrastructure Risk)

The core infrastructure supporting the web applications is severely outdated. The Nmap scan confirmed the host runs an End-of-Life Linux OS, alongside vulnerable service versions

including Apache httpd 2.2.14, OpenSSH 5.3p1, and Jetty 6.1.25. The continued use of these components creates a massive, easily exploitable attack surface and directly violates vendor management and patch compliance policies.

2.3. A01: Broken Access Control (High Risk)

The application's authorization scheme is fundamentally flawed. Testing confirmed that critical administrative interfaces are not properly protected, allowing unauthenticated or unprivileged users to access, bypass, or gain unauthorized control over core system functions. This directly violates the principle of least privilege.

The Bodgeit Store

We bodge it, so you dont have to! User: [dumarahim954@gmail.com](#)

[Home](#) [About Us](#) [Contact Us](#) [Logout](#) [Your Basket](#) [Search](#)

[Doodahs](#)
[Gizmos](#)
[Thingamajigs](#)
[Thingies](#)
[Whatchamacallits](#)
[Whatsits](#)
[Widgets](#)

Your Basket

Your basket had been updated.

Product	Quantity	Price	Total
Weird Widget	3	\$4.70	\$14.10
Thingie 3	1	\$3.30	\$3.30
TGJ ABB	1	\$1.40	\$1.40
Total	Update Basket		\$18.80

The Bodgeit Store

We bodge it, so you dont have to! User: [dumarahim954@gmail.com](#)

[Home](#) [About Us](#) [Contact Us](#) [Logout](#) [Your Basket](#) [Search](#)

[Doodahs](#)
[Gizmos](#)
[Thingamajigs](#)
[Thingies](#)
[Whatchamacallits](#)
[Whatsits](#)
[Widgets](#)

Admin page

UserId	User	Role	BasketId
1	user1@thebodgeitstore.com	USER	0
2	admin@thebodgeitstore.com	ADMIN	0
3	test@thebodgeitstore.com	USER	1
4	dumarahim954@gmail.com	USER	2

BasketId	UserId	Date
1	3	2025-09-22 07:22:27.029
2	4	2025-09-22 08:26:00.781
3	0	2025-09-22 08:27:30.382

BasketId	ProductId	Quantity
1	1	1
1	3	2
1	5	3
1	7	4
2	3	3
2	6	1
2	10	1

2.4. A02: Cryptographic Failures (High Risk)

User credentials and other sensitive data were observed being transmitted in cleartext due to a lack of enforced encryption. Furthermore, the Nmap scan confirmed the SSL certificate on Port 443 is expired. This combination guarantees that network eavesdropping can easily compromise user accounts, leading to a direct account takeover risk.

The screenshot displays the Burp Suite Professional interface. The top menu bar includes Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Learn. The main window is divided into three panes: HTTP history, Request/Response details, and the Inspector.

HTTP History Table:

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP
37	http://192.168.1.13	GET	/bodgeit/			404	633	HTML		404 Not Found			192.168.1.1
38	http://192.168.1.13	GET	/bodgeit/			404	633	HTML		404 Not Found			192.168.1.1
39	http://192.168.1.13	GET	/bodgeit/home.jsp			200	3416	HTML	jsp	The BodgeIt Store			192.168.1.1
40	http://192.168.1.13	GET	/bodgeit/home.jsp			200	3438	HTML	jsp	The BodgeIt Store			192.168.1.1
41	http://192.168.1.13	GET	/bodgeit/home.jsp			200	3406	HTML	jsp	The BodgeIt Store			192.168.1.1
42	http://192.168.1.13	GET	/bodgeit/login.jsp			200	2675	HTML	jsp	The BodgeIt Store			192.168.1.1
43	http://192.168.1.13	POST	/bodgeit/login.jsp		✓	200	2742	HTML	jsp	The BodgeIt Store			192.168.1.1
44	http://192.168.1.13	GET	/bodgeit/basket.jsp			200	3024	HTML	jsp	The BodgeIt Store			192.168.1.1
45	http://192.168.1.13	POST	/bodgeit/basket.jsp		✓	200	3065	HTML	jsp	The BodgeIt Store			192.168.1.1
46	http://192.168.1.13	GET	/bodgeit/login.jsp			200	2675	HTML	jsp	The BodgeIt Store			192.168.1.1
47	http://192.168.1.13	GET	/bodgeit/register.jsp			200	2717	HTML	jsp	The BodgeIt Store			192.168.1.1
48	http://192.168.1.13	POST	/bodgeit/register.jsp		✓	200	2801	HTML	jsp	The BodgeIt Store			192.168.1.1
49	http://192.168.1.13	POST	/bodgeit/register.jsp		✓	200	2801	HTML	jsp	The BodgeIt Store			192.168.1.1

Request Details (POST /bodgeit/login.jsp):

```
POST /bodgeit/login.jsp HTTP/1.1
Host: 192.168.1.13
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 31
Origin: http://192.168.1.13
Connection: keep-alive
Referer: http://192.168.1.13/bodgeit/login.jsp
Cookie: JSESSIONID=BC59EE163714E848349B99090592EEEB; acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada
Upgrade-Insecure-Requests: 1
Priority: u=0, i
username=root&password=owaspbwa
```

Response Details (HTTP/1.1 200 OK):

```
HTTP/1.1 200 OK
Date: Mon, 22 Sep 2025 12:11:18 GMT
Server: Apache-Coyote/1.1
Content-Type: text/html
Via: 1.1 127.0.1.1
Vary: Accept-Encoding
Content-Length: 2512
Keep-Alive: timeout=15, max=100
Connection: Keep-Alive
```

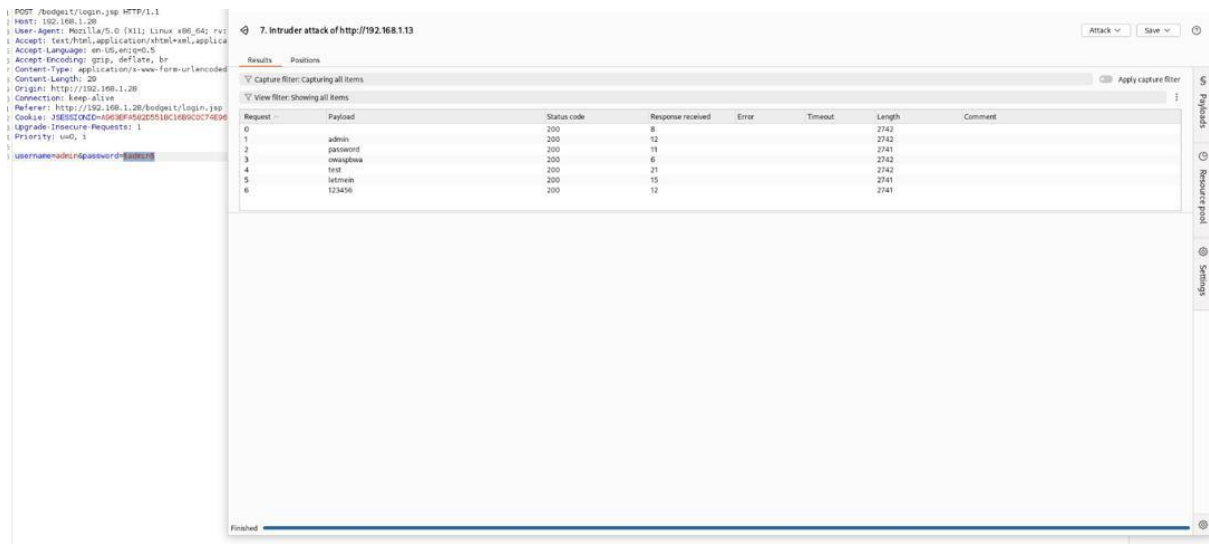
Inspector (HTML):

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2//EN">
<html>
<head>
<title>
The BodgeIt Store
</title>
<link href="style.css" rel="stylesheet" type="text/css" />
<script type="text/javascript" src="
../js/util.js">
</script>
</head>
<body>
<center>
<table width="80%" class="border">
<tr BGCOLOR="#C3D9FF">
<td align="center" colspan="6">
<h1>
The BodgeIt Store
</h1>
<table width="100%" class="noborder">
<tr BGCOLOR="#C3D9FF">
<td align="center" width="30%">
&nbsp;
</td>
<td align="center" width="40%">
We bodge it, so you dont have to!
</td>
<td align="center" width="30%" style="text-align: right">

```

2.5. A07: Identification and Authentication Failures (Medium Risk)

The BodgeIt Store application utilizes a weak password policy. This failure makes user accounts susceptible to simple brute-force attacks and dictionary attacks, serving as a lower-friction entry point for attackers seeking to establish persistence.



3. Discovery and Infrastructure Findings (Nmap Analysis)

The Nmap scan results further detail the foundational misconfigurations and component vulnerabilities:

- **Outdated Services:** Multiple instances of old software versions were found, including the high-risk Java Object Serialization service on port 5001.
- **Security Misconfiguration (A05):** The Samba file-sharing service is operating with message_signing: disabled, which is a dangerous default that permits Man-in-the-Middle attacks against file traffic.
- **Misconfigured SSL:** The certificate on Port 443 expired in December 2022, causing client trust warnings and violating internal security standards.

4. OWASP Top 10 Risk Assessment Table

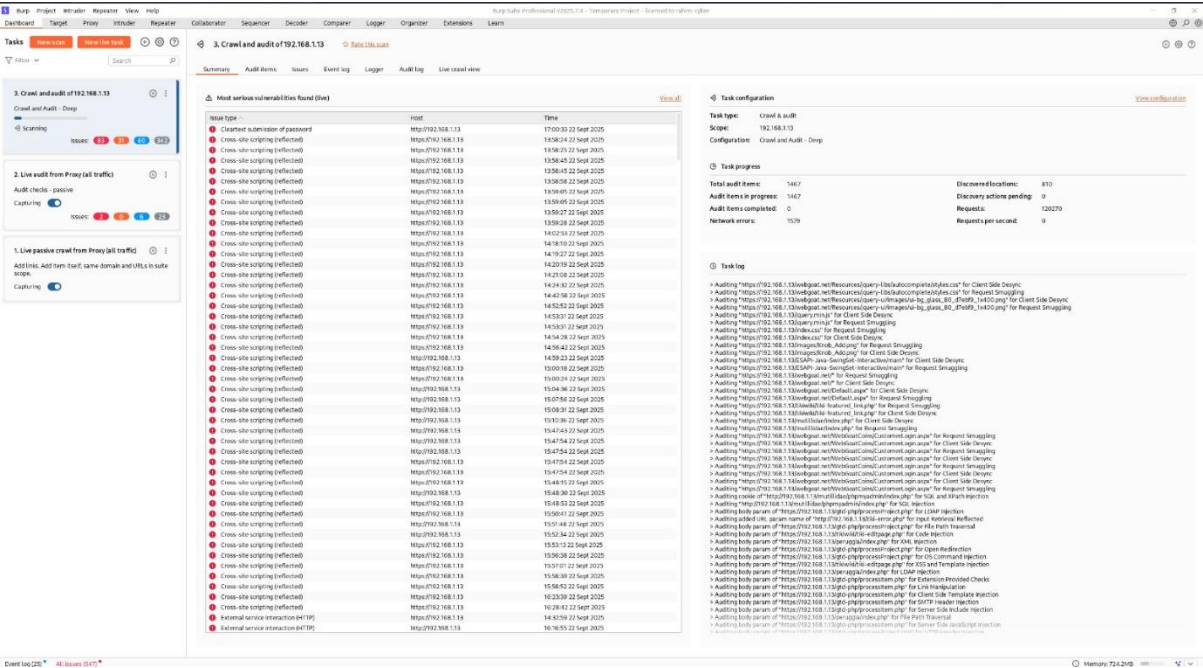
OWASP Category	Vulnerability Example	Affected Application / Component	Inherent Risk (L/M/H)	Compliance Violation	Business Impact
A03: Injection	SQL Injection	Bodgeit Store Search/Login	Critical	PCI DSS 6.5.1, GDPR (Data integrity loss)	Full database compromise, sensitive data exfiltration, service outage.
A01: Broken Access Control	Unprotected Admin Page	Bodgeit Store	High	PCI DSS 7.2.1, SOX (Unauthorized)	Privilege escalation, unauthorized system configuration, data tampering.

				d modification)	
A06: Vulnerable/Outdated Components	Multiple Outdated Services	Apache 2.2.14, OpenSSH 5.3p1, Linux 2.6.x	Critical	PCI DSS 6.1 (Patching), Vendor Management	System takeover (RCE), denial of service, failure to meet security baselines.
A02: Cryptographic Failures	Cleartext Password Transmission	WebGoat / All HTTP services	High	PCI DSS 4.1, GDPR (Data confidentiality)	Credential theft, session hijacking, account takeover.
A07: Auth. Failures	Weak Password Policy	Bodgelt Store	Medium	NIST CSF PR.AC-1	Low-effort user account compromise, use of common passwords.

5. Supporting Evidence (Deliverables)

5.1. Burp Suite Dashboard: Scan Results

The dashboard validates the scope and severity of the audit, confirming **5 High Severity Issues** and **1 Medium Severity Issue** across the scope of the assessment.



6. Recommended Actions

1. **Immediate Mitigation:** Isolate the 192.168.1.13 server from all untrusted networks.
2. **Infrastructure Upgrade:** Migrate all services (OS, Apache, OpenSSH) to current, supported versions to address the A06 risk. All services must adhere to secure baseline configurations (A05).
3. **Application Remediation:** Development teams must be tasked with immediate fixes:
 - **A03 (Injection):** Implement parameterized queries for all database calls.
 - **A01 (Access Control):** Enforce server-side authorization checks on all restricted endpoints.
 - **A02 (Cryptographic):** Enforce HSTS and TLS 1.2+ for all communication.
4. **Process Improvement:** Mandate security training for developers and integrate SAST/DAST tools into the CI/CD pipeline.
5. **Re-testing:** Commission an independent penetration test to validate all fixes before the system is considered secure.

7. Conclusion

The targeted security assessment of the owaspbwa server confirms a critical failure to meet current application security standards. By employing advanced manual and automated techniques, we successfully identified and validated high-impact vulnerabilities across five categories of the OWASP Top 10, most notably SQL Injection and systemic use of outdated components. For the organization, this understanding of the mechanics of web application flaws is essential for validating security controls, assessing vendor risk, and ensuring that software development practices are secure and compliant. Given the severity of the confirmed risks, particularly the data breach potential, immediate and decisive action on the recommended mitigation plan is non-negotiable for protecting the company's assets and maintaining regulatory compliance.